



# CodeRisk Security Report

AI-Powered Code Security Analysis

Task: cr-  
20260818-  
demo

Date: 2026-08-  
18T10:50:00

Source:  
github.com/a9320/code-  
risk-agent

Total: 4  
findings

1

CRITICAL

1

HIGH

1

MEDIUM

1

LOW

0

INFO

## Findings

CRITICAL

### SQL Injection in user\_query()

📁 app/db.py:42 | Rule: CWE-89

User input from request.args directly interpolated into SQL string via f-string. Use parameterized queries instead.

HIGH

### Hardcoded API Key

📁 config/settings.py:12 | Rule: CWE-798

Stripe secret key hardcoded as string literal. Move to environment variables.

MEDIUM

### Missing CSRF Protection

📁 app/views.py:88 | Rule: CWE-352

POST endpoint /transfer lacks CSRF token validation.

LOW

## Verbose Error Messages

📁 app/handlers.py:15 | Rule: CWE-209

Stack trace exposed to client in production mode.

🔑 **Digitally Signed** — SHA-256:

ef53dc165a58233d9d6818ab208c8f2d03b0ff84b2dee024a0902f9448429c51

Generated by CodeRisk Cloud v1.0.0 | Powered by Nutrient DWS

---

CodeRisk Cloud © 2026 | AI溢出安全实验室 (Overflow Security Lab)

This report was generated automatically. Manual review recommended for all findings.